Shavaughn Hamilton

Summarized Description of Third Party Risk Management Project:

- Conducted a **Third-Party Risk Assessment** on a key **SaaS provider** for a company's **scientific data analysis platform**.
- Evaluated **security policies, vulnerability management, IAM controls, and incident response capabilities** using a structured **TPRM questionnaire.**
- Identified **High-Risk Deficiencies,** including: Lack of a d**edicated cybersecurity team or security framework**, Absence of a **vulnerability management & penetration testing program**, Inadequate **security monitoring and incident response capabilities,** & Weak **Identity & Access Management (IAM)** controls, increasing the risk of **unauthorized access.**
- Highlighted **Medium-Risk Issues**, such as **Data Loss Prevention (DLP) gaps**, recommending **enhanced monitoring** to detect unauthorized data exfiltration.
- Provided **risk mitigation strategies**, advising Oscorp's senior management on **contractual security requirements** for SaaS providers, ensuring alignment with the **company's security standards.**

Third Party Risk Management

by Shavaughn Hamilton

Oscorp really enjoyed working with you and they decided to extend the contract with your employer. They have a new assignment for you: TPRM.

One of Oscorp's key suppliers is Horizon Labs. They provide Oscorp with a Software-as-a-Service (SaaS) application. Oscorp uses this SaaS application for scientific data analysis.

You are tasked with conducting a security assessment on Horizon Labs as a supplier. You send a TPRM questionnaire to Horizon Labs and they provided you with answers.

We will assume that Horizon Labs provided you with sufficient evidence.

Problem:

Go over the questions and answers and summarize the key risk items that should be escalated to Oscorp's senior management.

GRC Mastery Supplier Assessment Questionnaire (Sample for learning purposes)			
Number	Question	Answer	Comment
1	Enter your name, address, and contanct details	Peter Parker,IT Manager at Horizon Labs. Address: 20 Ingram Street, Queens, New York. Email: peter.parket@horizonlabs.com	
2	Describe the service that you provide to Oscorp	We provide a SaaS solution called "Horizon X". This is a SaaS application used to provide Data Analysis service for Scientific Research purposes.	
3	Do you handle sensitive data? If yes, is the data encrypted?	The application handles confidential data. The data is intellectual property data that belongs to Oscorp. The database used in the backend is Oracle Database. The database encrypts the data by default.	
4	Does your organisation follow a cyber security framework?	Horizon Labs is a startup, we still don't follow cyber security frameworks	
5	Do you have a vulnerability management program in place?	We don't have a vulnerability scanner but we install regular updates to our windows servers	
6	Do you undertake regular enterprise wide penetration testing? When was the last penetration test conducted?	We haven't done a penetration test yet, but we are plan to run one in the future.	
7	Describe how your organisation handles security detection and monitoring	Our IT team deals with all IT issues	
8	Describe your incident response capability	The IT team manages all incidents	
9	Do you utilise Multi-factor authentication?	Yes, we use Okta for two factor authentication	
10	Do you employ role-based access control?	No	
11	Is the principle of least privileges followed?	No	
12	Do you implement Segregation of duties for critical application?	No	
13	Do you conduct period user access reviews?	No	
14	Do you conduct regular user security education awareness training and educational campaigns?	We have a security training module that's mandatory for anyone who joins the company	
15	Do you have Data Loss Protection (DLP) capability in place?	No, but we take regular backups	

Shavaughn Hamilton's Practical Assessment Solution: TPRM

Based on the responses to the questionnaire, in the file, these are the Key risk items that should be escalated to Oscorp's senior management, and evidence should be provided:

3) Decide which data needs to be encrypted based on it's classification. Data classified as sensitive and private should be prioritized.

4) A security framework should be decided on and followed.

5) Regular updates are good, but there should be a robust vulnerability management program in place with a vulnerability scanner.

6) Regular enterprise-wide penetration testing should be employed, with specific and scheduled dates and evidence of results. Recommended at least once annually for smaller companies and quarterly for larger companies, or whenever significant changes occur such as storing, processing and transmitting data, adding new network infrastructure or applications, applying security patches, Establishing new office locations, changes in cyber policies, and company acquisitions and mergers.

7) Be more descriptive on what software, roles, and methods are being used as it pertains to handling security detection and monitoring.

8) Be more descriptive on what software, roles, and methods are being used as it pertains to handling security detection and monitoring

10) Role-based access control: Not employing RBAC creates a cybersecurity risk because if many people have access to things that don't pertain to their role, if they were to be compromised by a cyber attack, the attackers would be able to do more damage than if their access to just one role was granted.

11) Principle of least privileges: This is the principle used in Role-based access control, which is a necessity to reduce the potential of a cybersecurity attack, or an IT mistake occurring.

12) Segregation of duties for critical applications: This should be implemented to create a safer, risk averse and more robust IT environment. It reduces the risk and impact of fraud or an error/ mistake by one individual.

13) Period user access reviews: Implementing periodic evaluations of the access rights of users to an organization's systems and applications ensures that users only have access to the resources they need to do their job, and to remove any unnecessary or inappropriate privileges. This process helps security teams, compliance managers, and business owners understand who has access to what, and make informed decisions about whether that access is necessary. For example, a UAR can help identify if a former employee still has access to sensitive data, which could pose a security risk.

14) Cybersecurity awareness education should still occur at least once a year (every quarter/ bi-annually for larger companies.) since technology evolves. Have a web-based course that trains employees on passwords, phishing emails, scams, social engineering. Everyone who falls for a phishing attack should receive a targeted training course about phishing and how not to fall for it. Some organizations do it every 3 months, 6 months or once a year.

15) Data Loss Protection (DLP) capability: Regular backups alone are not sufficient for Data loss prevention. Environment needs to be scanned to see if any sensitive information is leaving the organization and an alert should be generated for a cybersecurity professional/ investigator. Data will then need to be optimally classified as sensitive, confidential or public so that the proper useful alerts for only sensitive and confidential data (such as people's names, financial information) will generate alerts that can be employed. (Can't encrypt everything (additional costs, longer data processing, larger file size) or use DLP on all data because it will generate thousands of alerts and stop the business from running), so data must be classified as sensitive, confidential or public. Organizations will need a data classification policy/information classification policy. Backups also need to be tested regularly.

Additional questions: Is there any employee cybersecurity awareness education?
Recommendation: Have a web-based course that trains employees on passwords, phishing emails, scams, social engineering, needs to run periodically upon new employee onboarding and at least once a year, (every quarter/ bi-annually for larger companies.) Everyone who falls for a phishing attack should receive a targeted training course about phishing and how not to fall for it. Some organizations do it every 3 months, 6 months or once a year.

—

There are some obvious high risk items. Here is a summary:

- Horizon Labs don't have a cyber security team or a proper cyber security capability. The IT team manages cyber security. They don't follow a cyber security framework. Therefore, Horizon Labs don't have sufficient cyber security capability which poses a High risk to Oscorp.

- Horizon Labs don't have a vulnerability management program or a penetration testing program. This is another High risk issue.

- Lack of cyber security detection and monitoring capability is a High risk issue.

- Horizon Labs is not capable of responding to cyber security incidents. This is a High risk issue.

- Significant deficiency in the area of Identity and Access Management. This is a high risk issue.

- DLP: Horizon Labs encrypt data and take regular backups. However, they don't monitor for Data loss issues. This a Medium risk. It would be High if they didn't encrypt the data or take backups.